

Αλληλεπίδραση και αμφίδρομη επίδραση ποιότητας και ασφάλειας λογισμικού και πηγαίου κώδικα σε τροποποιήσεις του πηγαίου κώδικα του λογισμικού

Εμπειρική ανάλυση pull requests με στατιστική ανάλυση, ιεραρχικά μοντέλα και πολυμεταβλητές τεχνικές

Αναστάσιος Τσάλμας – Τμήμα Εφαρμοσμένης Πληροφορικής – Πανεπιστήμιο Μακεδονίας

Επιβλέπων: Απόστολος Αμπατζόγλου, Νικόλαος Νικολαΐδης – Θεσσαλονίκη, Σεπτέμβριος 2026

Με μια ματιά

- Η πολυπλοκότητα συνδέθηκε σταθερά με μεγαλύτερη πυκνότητα προβλημάτων συντηρησιμότητας
- Το project εξηγεί πολύ μεγάλο μέρος της διακύμανσης των quality-security outcomes
- Η κατηγορία quality/security/both δεν ήταν σταθερός ανεξάρτητος predictor
- Οι μετρικές οργανώθηκαν σε περισσότερες από μία υποκείμενες διαστάσεις
- Η χρονική αλληλεπίδραση base-closed δεν μπορούσε να ελεγχθεί αξιόπιστα λόγω ανεπαρκούς μεταβλητότητας

Ποιότητα και ασφάλεια στην έρευνα

Ποιότητα

- ▶ Συντηρησιμότητα
- ▶ Αξιοπιστία
- ▶ Code smells
- ▶ Duplication
- ▶ Πολυπλοκότητα

Ασφάλεια

- ▶ Security issues
- ▶ Vulnerabilities
- ▶ Security hotspots

Finding ΔEN σημαίνει αυτομάτως πραγματικό defect, exploitable vulnerability ή security risk.

Security hotspot: σημείο το οποίο απαιτεί ανθρώπινο ενδιαφέρον, όχι επιβεβαιωμένη ευπάθεια.

Pull Requests και ερευνητικό κενό

- ▶ Το PR συνδυάζει: (1) αλλαγή κώδικα, (2) review, (3) metadata, (4) τελικό snapshot
- ▶ Βρίσκεται ανάμεσα στο πολύ **λεπτό** επίπεδο commit και στο πολύ **γενικό** επίπεδο repository
- ▶ Η βιβλιογραφία εξετάζει συχνά ποιότητα και ασφάλεια χωριστά
- ▶ **Κενό:** κοινή εξέταση πολλών quality/security metrics, ετερογένεια project και λανθάνουσα δομή
- ▶ Μονάδα ανάλυσης: ένα PR – Επίπεδο ομαδοποίησης: Project



ΣΚΟΠΟΣ

- Κοινή, ιεραρχική και πολυμεταβλητή εξέταση των δύο διαστάσεων.

Σχέση και δομή

- RQ1, ποιότητα-ασφάλεια
- RQ4, υποκείμενες διαστάσεις

Predictors και context

- RQ2, χαρακτηριστικά κώδικα / PR
- RQ3, Διαφορές projects

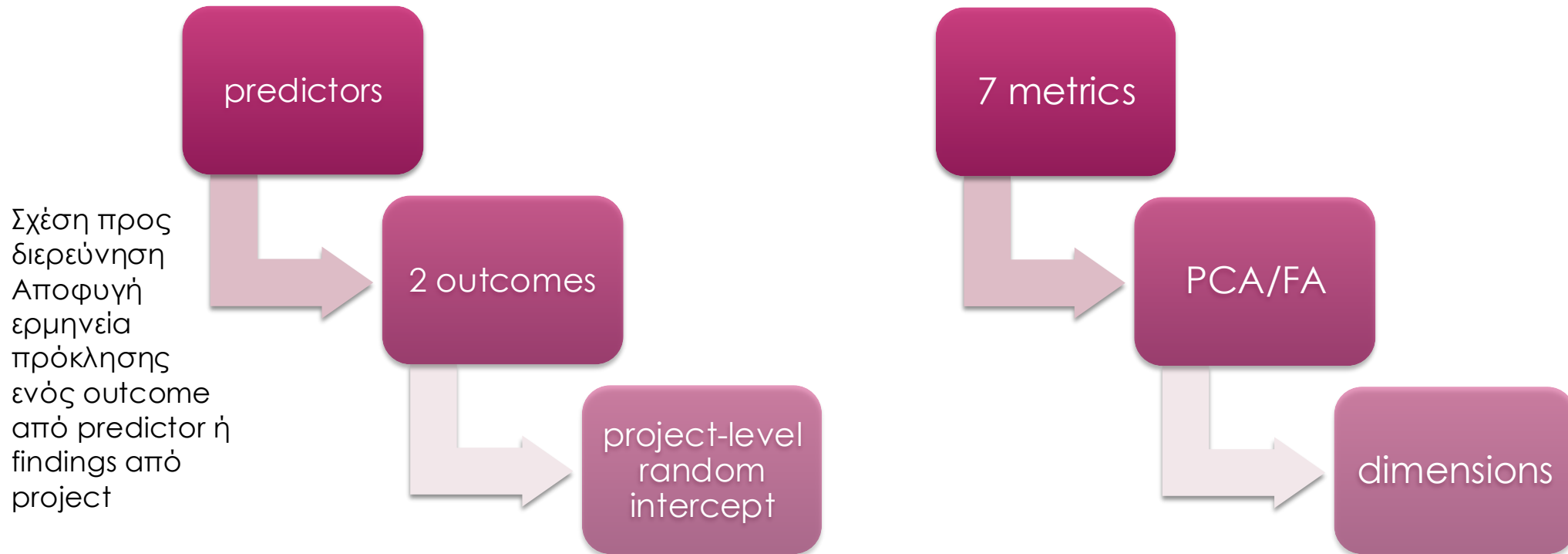
Χρονική διάσταση

- RQ5, σύνδεση μεταβολών base-closed

Κατηγορίες

- RQ6, διαφοροποίηση quality/security/both

Τελικό εννοιολογικό μοντέλο και όρια ερμηνείας



Ερευνητικός σχεδιασμός και συνολικό pipeline

Repository selection & PR collection

Snapshot generation: pr_base-pr_closed

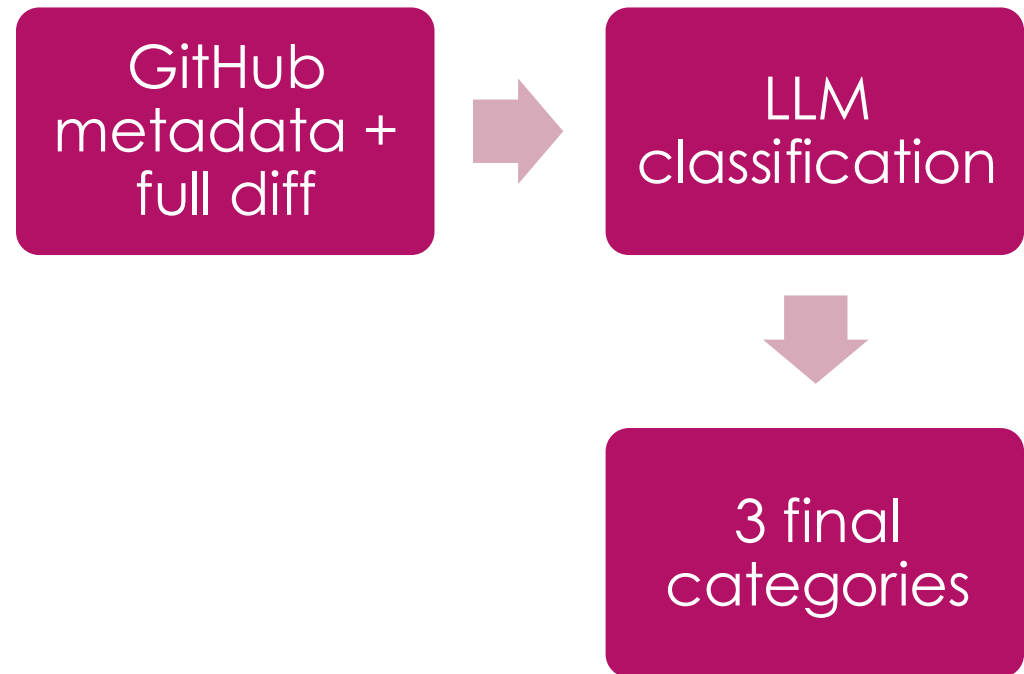
SAST & metrics extraction

Data cleaning, filtering, normalization

Statistical analysis & σύνθεση αποτελεσμάτων

Πηγή και κατηγοριοποίηση δεδομένων PRs

- ▶ **Αρχική δεξαμενή:** 2.839 δημόσια, ενεργά, production-oriented repositories
- ▶ **GitHub/GitHub API:** PR metadata & full .diff/.patch
- ▶ **LLM:** gpt-oss-120b, multi-label classification
- ▶ **Αρχικά labels:** code_quality, software_quality, code_security, software_security
- ▶ **Τελική αποτύπωση:** quality, security, both



Snapshots, SAST & metrics

pr_base

Ανακατασκευασμένη κατάσταση πριν την ενσωμάτωση της αλλαγής

pr_closed

Τελικό αναλυόμενο snapshot που συνδέεται με το ολοκληρωμένο PR

Δομή

NCLOC, complexity, cognitive complexity, duplicated lines density

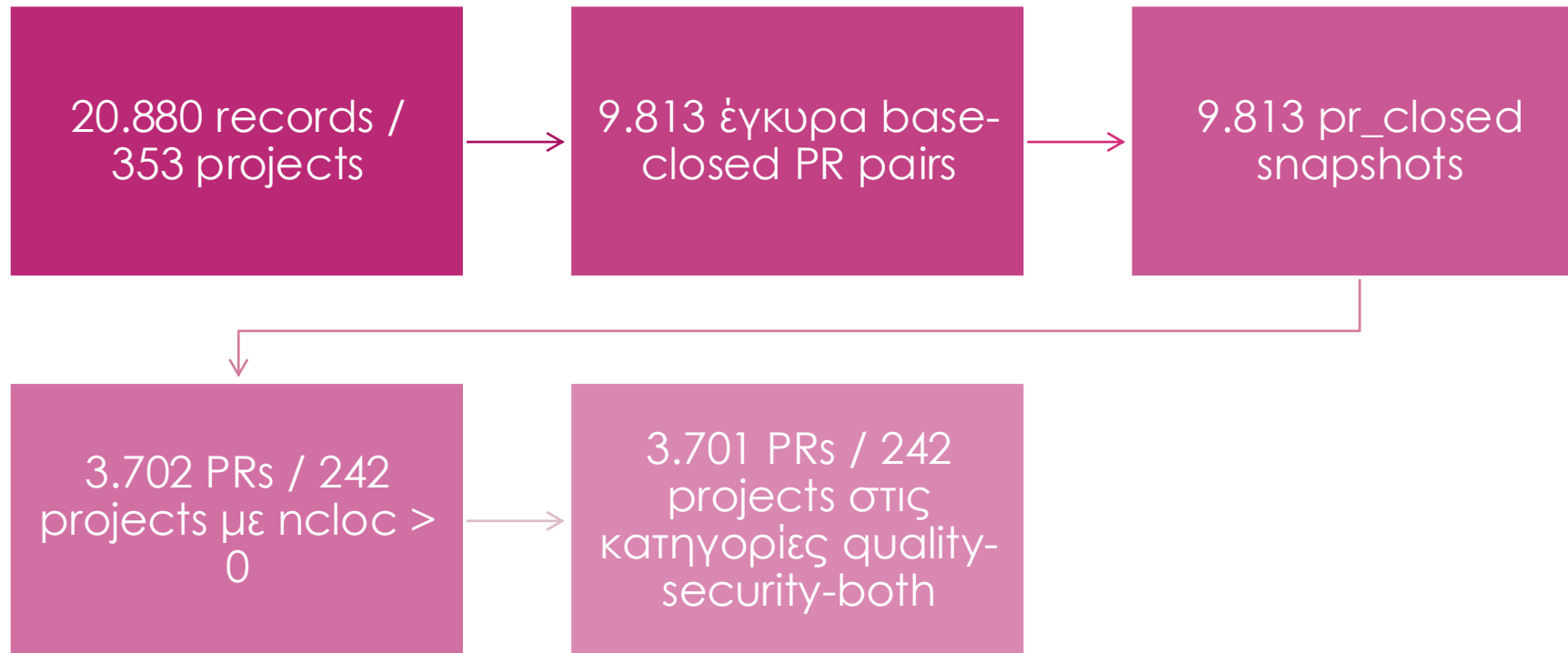
Ποιότητα

Bugs, Code Smells, reliability issues, maintainability issues

Ασφάλεια

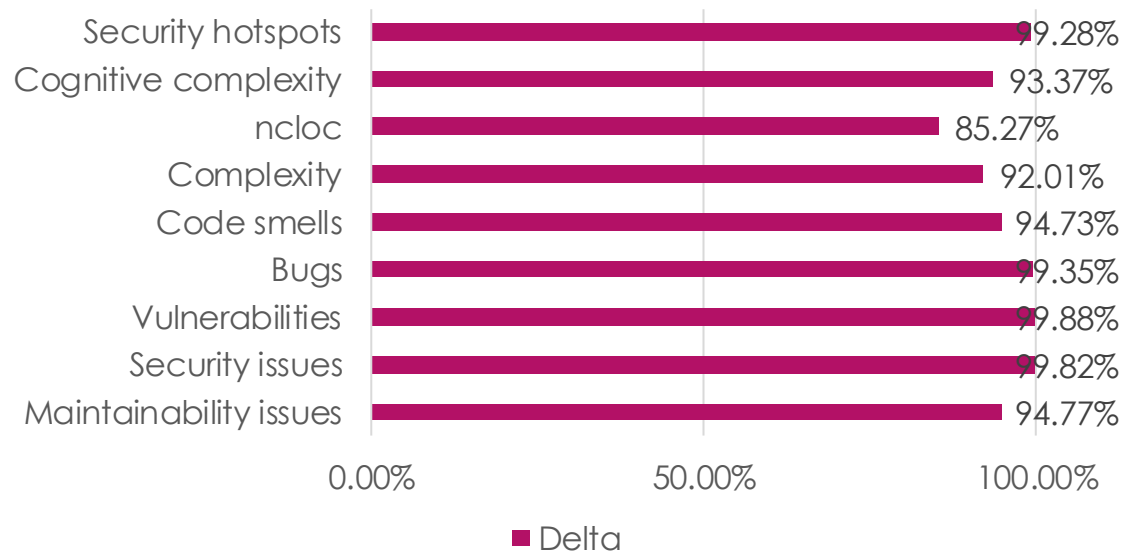
Vulnerabilities, Security hotspots, Security Issues

Ροή φιλτραρίσματος και τελικό δείγμα



Κρίσιμη μεθοδολογική προσαρμογή

Ποσοστό PRs χωρίς μεταβολή ανά μετρική



- ▶ 94% - 99,9% των PRs είχαν ίδιες τιμές base και closed
- ▶ $(\Delta_{\text{Maintainability Issues}} = 0) > 94\%$
- ▶ $(\Delta_{\text{Security Issues}} = 0) > 99\%$
- ▶ Περίπου 60% των αρχικών παρατηρήσεων με NCLOC = 0
- ▶ **Τελική στρατηγική:** cross-sectional, ένα pr_closed ανά PR, NCLOC > 0

Αναλυτικές μεταβλητές και κανονικοποίηση

$$\text{KLOC} = \text{NCLOC} / 1000$$

$$\text{Quality Density} = \text{Maintainability Issues} / \text{KLOC}$$

$$\text{Security Density} = \text{Security Issues} / \text{KLOC}$$

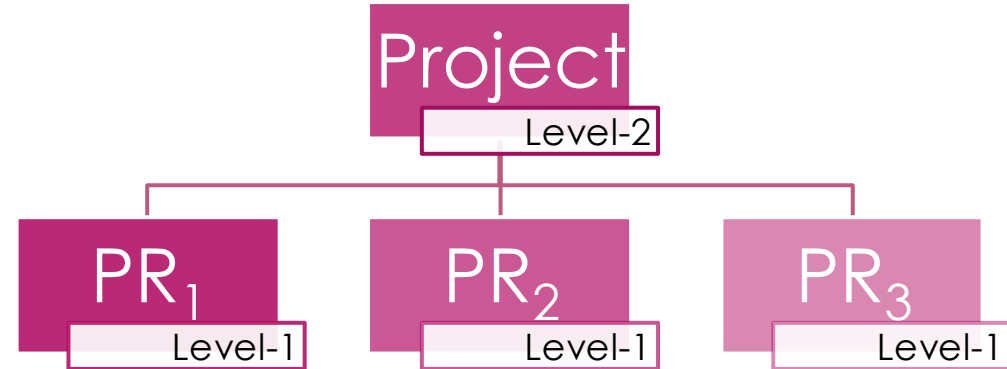
$$\text{Outcomes: } \log(1 + \text{density})$$

$$\text{Predictors: } \log(1 + \text{Complexity}), \log(1 + \text{NCLOC}), \text{Category}$$

$\log_1 p$: κρατά έγκυρες τις μηδενικές τιμές

Ιεραρχική δομή και ρόλος κάθε μεθόδου

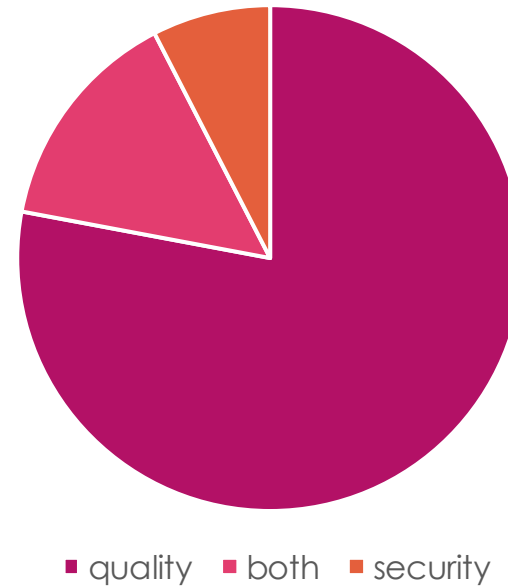
- ▶ OLS με project-clustered robust SE: pooled baseline model
- ▶ Random-intercept LMM: κύριο μοντέλο, project variance και partial pooling
- ▶ PCA: συμπύκνωση συνολικής διακύμανσης
- ▶ FA: κοινή/λανθάνουσα δομή
- ▶ Negative Binomial & GEE: εναλλακτικά robustness estimands



Δομή τελικού δείγματος

- ▶ 3.701 Pull Requests – 242 projects
- ▶ PRs/project: 15,3 – διάμεσος 8 – [1, 85]
- ▶ quality: 2.885 PRs (78,0%)
- ▶ both: 536 PRs (14,5%)
- ▶ security: 280 PRs (7,6%)

Categories



Quality & Security μετρικές

Quality

- ▶ Quality density: διάμεσος 9,02 issues/KLOC – 22,48% μηδενικές τιμές

Security

- ▶ Security Density: διάμεσος 0 – 78,36% μηδενικές τιμές
- ▶ Security Issues: μόνο 801 από 3.701 PRs
Θετική τιμή

OLS baseline αποτελέσματα

- ▶ Quality: log_complexity $\beta=0,368$, $p<0,001$
- ▶ Quality: log_ncloc $\beta=-0,169$, $p=0,021$
- ▶ Quality model: $R^2=0,339$ – $F=23,32$, $p<0,001$
- ▶ Security model: $R^2=0,006$ – κανένας predictor, $p<0,05$
- ▶ Security-Both δεν ήταν σημαντικές σε κανένα OLS outcome

Κύρια LMM αποτελέσματα – fixed effects

log_complexity

- ▶ **Quality:** $\beta=0,398$, 95% CI [0,355, 0,442], $p<0,001$
- ▶ **Security:** $\beta=-0,011$, 95% CI [-0,020, -0,002], $p=0,017$

log_ncloc

- ▶ **Quality:** $\beta=-0,152$, 95% CI [-0,203, -0,101], $p<0,001$
- ▶ **Security:** $\beta=-0,004$, $p=0,455$

Ta Category Effects είναι μη σημαντικά και στα δύο components

Project-level ετερογένεια και ICC

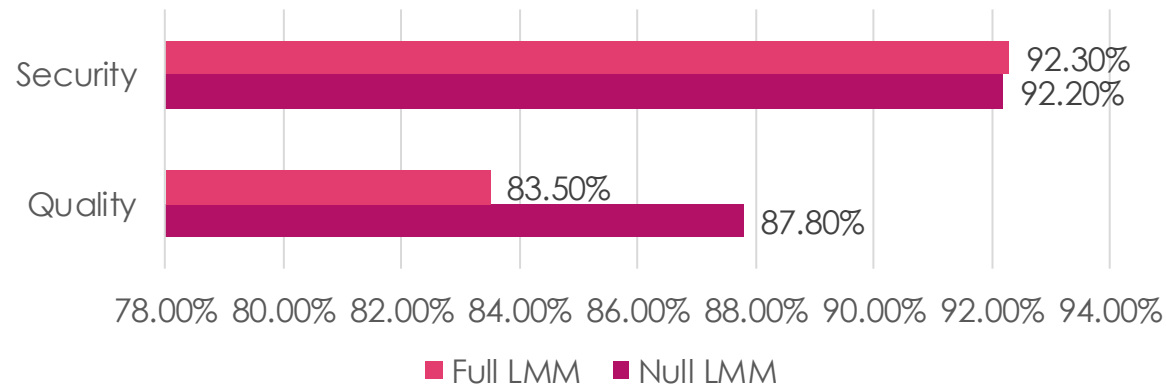
Null LMM

- ▶ Quality ICC: 87,8%
- ▶ Security ICC: 92,2%

Full LMM

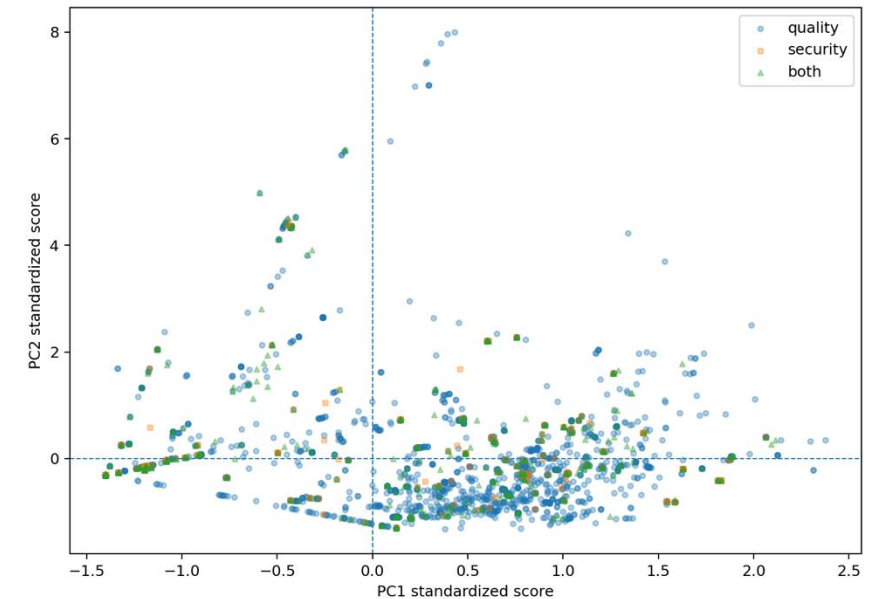
- ▶ Quality ICC: 83,5%
- ▶ Security ICC: 92,3%

Μετάβαση ICC από Null σε Full LMM



Principal Component Analysis

- ▶ PC1: 40,1%
- ▶ PC2: 22,1%
- ▶ PC3: 15,3%
- ▶ Cumulative variance: 77,5%
- ▶ Οι κατηγορίες PR αλληλοεπικαλύπτονται στον χώρο PC1-PC2



Factor Analysis

- ▶ KMO = 0,631 – μέτρια καταλληλότητα
- ▶ Bartlett: $\chi^2=13.877,232$, $df=12$, $p<0,001$
- ▶ **F1:** complexity=0,959 – cognitive complexity=0,985 – maintainability=0,484
- ▶ **F2:** reliability=0,807 – maintainability = 0,589 – duplication = 0,418
- ▶ **F3:** security hotspots=0,759 – security issues=0,436 – πιο εύθραυστος

Robustness & sensitivity analyses

- ▶ **Projects με ≥ 5 Prs:** 3.544 PRs / 149 projects – quality $\beta_{\text{ncloc}} = -0,141$, $\beta_{\text{complexity}} = 0,369$
- ▶ **Negative Binomial:** security category $\rightarrow$ λιγότερα maintainability counts ($p = 0,003$), both $\rightarrow$ περισσότερα security counts ($p = 0,002$)
- ▶ **GEE security share:** $p_{\log_{\text{ncloc}}} = 0,527$, $p_{\log_{\text{complexity}}} = 0,135$
- ▶ **Size-adjusted PCA/FA:** 2 αντί για 3 διαστάσεις – PCA cumulative variance 65,7%

Σταθερά

project

Complexity-quality

Ευαίσθητα

Category effects

Security coefficient

3 vs 2 dimensions

Τα πέντε ισχυρότερα ευρήματα

Πολύ ισχυρή project-level ετερογένεια – ICC έως και 92,3%

Σταθερή θετική σύνδεση complexity και quality/maintainability

Περιορισμένη και μη σταθερή επίδραση της PR Category

Πολυδιάστατη δομή quality-security – όχι ένας ενιαίος άξονας

Τα διαθέσιμα snapshots πληροφορούν καλύτερα για διαφορές μεταξύ PRs/projects παρά για within-PR μεταβολές

Απαντήσεις στα ερευνητικά ερωτήματα

- ▶ **RQ1:** όχι μία μοναδική ισχυρή σχέση – σύνθετη και πολυδιάστατη δομή
- ▶ **RQ2:** complexity ο πιο σταθερός predictor του quality outcome – security σχέσεις ασθενείς
- ▶ **RQ3:** πολύ μεγάλο μέρος της διακύμανσης βρίσκεται μεταξύ projects
- ▶ **RQ4:** ναι, 3 κύριες διαστάσεις – 2 μετά το size adjustment
- ▶ **RQ5:** δεν απαντήθηκε αξιόπιστα λόγω 94%-99,9% μηδενικών μεταβολών
- ▶ **RQ6:** δεν βρέθηκαν σταθερές διαφορές ανά category

Κατάσταση ερευνητικών υποθέσεων

- ▶ **H1:** σχέση μεταβολών quality-security: μη αξιολογήσιμη
- ▶ **H2:** χαρακτηριστικά PR/snapshot: μερικώς υποστηρίζεται cross-sectionally
- ▶ **H3:** project-level ετερογένεια: υποστηρίζεται ισχυρά
- ▶ **H4:** λανθάνουσες/υποκείμενες δομές: υποστηρίζεται επαρκώς
- ▶ **H5:** ανάγκη ιεραρχικής μοντελοποίησης: υποστηρίζεται επαρκώς
- ▶ **H6:** συνέργειες και αντισταθμίσεις μεταβολών: μη αξιολογήσιμη

Πρακτικές επιπτώσεις

- ▶ **Code review:** προτεραιοποίηση με complexity, maintainability, security indicators και project history
- ▶ **CI/CD και DevSecOps:** παράλληλοι quality & security checks σε όλα τα PRs
- ▶ **Quality/security gates:** project-specific baselines αντί για καθολικά thresholds
- ▶ **Κλιμακωτή αντίδραση:** warning → πρόσθετο review/testing → προσωρινό block
- ▶ Τα ευρήματα δεν αποτελούν έτοιμο risk score ή predictive model

Περιορισμοί και απειλές εγκυρότητας

Κατασκευή:
SonarQube
findings είναι
proxies – Category
χωρίς ανεξάρτητη
χειροκίνητη
επιβεβαίωση

Internal:
observational
design,
confounders και
καμία causal
attribution στο PR

External:
skew/zeros, άνισα
clusters, ratio
denominator και
model-sensitive
results

Temporal:
ανεπαρκής base-
closed variability
για longitudinal
conclusions

Τελικό συμπέρασμα

- ▶ Η αξιολόγηση ποιότητας και ασφάλειας είναι context-aware και πολυμετρικό πρόβλημα, όχι ένας ενιαίος δείκτης ή μία καθολική σχέση.

Complexity

- Σταθερή σύνδεση με επιβάρυνση maintainability

Project context

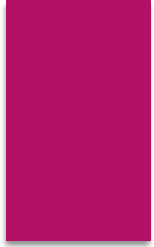
- Κυρίαρχη πηγή ετερογένειας

Category

- Περιορισμένη σταθερή προβλεπτική αξία

Μελλοντική ανάγκη

- Πραγματικά διαχρονικά, λεπτομερέστερα και πλουσιότερα security δεδομένα



Πλήρης διατύπωση των έξι RQs

Υπάρχει στατιστικά σημαντική σχέση και ισχυρή σχέση μεταξύ δεικτών ποιότητας και δεικτών ασφάλειας λογισμικού σε Pull Requests;

Ποια χαρακτηριστικά του PR, του τελικού snapshot και του project σχετίζονται με αυξημένη πυκνότητα προβλημάτων ποιότητας και ασφάλειας;

Σε ποιο βαθμό οι διαφορές μεταξύ projects εξηγούν τη διακύμανση των προβλημάτων ποιότητας και ασφάλειας;

Μπορούν οι επιμέρους μετρικές να αναχθούν σε μικρότερο αριθμό υποκείμενων διαστάσεων;

Συνδέονται οι μεταβολές ποιότητας base-closed με αντίστοιχες μεταβολές ασφάλειας;

Υπάρχουν κατηγορίες PR στις οποίες η σχέση ποιότητας-ασφάλειας διαφοροποιείται;

Ακριβής προδιαγραφή κύριων μοντέλων

- ▶ **Outcome 1:** $\log(1 + \text{Maintainability issues} / \text{KLOC})$
- ▶ **Outcome 2:** $\log(1 + \text{Security issues} / \text{KLOC})$
- ▶ **Fixed effects:** $\log(1 + \text{NCLOC})$, $\log(1 + \text{Complexity})$, Category with quality as reference
- ▶ **OLS:** project-clustered robust standard errors
- ▶ **LMM:** random intercept per project, final models estimated with REML

Συμφιλίωση των αριθμών φιλτραρίσματος

20.880

- Αρχικές εγγραφές, όχι PRs

9.813

- PRs με ακριβώς μία pr_base και μία pr_closed κατάσταση

298

- PRs με μη τυπικό αριθμό εγγραφών (περίπου 298*2 rows)

3.702

- pr_closed PR observations με NCLOC > 0

3.701

- Τελικές κατηγοριοποιημένες PR observations

Βασικά περιγραφικά στατιστικά

	Μέσος όρος	Μέσος	P95	Zeros - 0
Quality Density	28,11	9,02	106,43	22,48%
Security Density	0,337	0	0,749	78,36%
Maintainability Issues		12		22,48%
Security Issues		0		78,36%
Vulnerabilities				80,98%
Security Hotspots				54,36%

Μελλοντική έρευνα

- ▶ Πραγματικά διαχρονικά σύνολα δεδομένων και security patch pairs
- ▶ Ανάλυση σε επίπεδο commit, file ή function
- ▶ Συνδυασμός SAST, DAST, Software Composition Analysis (SCA), secret/IaC scanning και runtime evidence
- ▶ Σύνδεση με επιβεβαιωμένα CVEs και exploitation evidence
- ▶ Generalized Linear Mixed Models, και άλλα μοντέλα στατιστικής
- ▶ Ανεξάρτητη validation της LLM classification και διαφορετικά ecosystems/languages